

Personal Security Policy

A governance document that serves as a north star for guiding information security management.

Owner
[Your Name]

Created
[YYYY-MM-DD]

Version
1.0

1. DEVICE SCOPE

All devices considered in scope for this policy. Update whenever devices are added or retired.

Type	Name / Model	OS & Version	Serial Number	FDE	Supported
Laptop	[MacBook Pro M1]	[macOS 15.x]	[123-XYZ]	✓	✓
Phone	[iPhone 15]	[iOS 18.x]	[123-XYZ]	✓	✓
Router	[Model]	[Firmware x]	[123-XYZ]	—	✓

2. DATA CLASSIFICATION

Every category of data you hold, its classification tier, where it is stored, and the controls required to protect it.

● Secret

Loss or exposure causes serious harm (e.g., password vault master password, private keys, cryptocurrency seed phrases, TOTP codes).

Controls & Safeguards:

- Encryption at rest
- 3-2-1 backup
 - 3 copies
 - 2 media types
 - 1 off-site storage
- Fully air-gapped
- Succession plan

● Confidential

Exposure is damaging; loss is painful but survivable (e.g., Financial documents, ID scans, medical records, passwords).

Controls & Safeguards:

- Encryption at rest
- Multi-Factor Authentication
- 2 copies
- E2E encryption for cloud storage
- Succession Plan

● Public

Non-sensitive information where exposure and loss do not cause harm (e.g., photos, notes, regular computer files).

Controls & Safeguards:

- Device/user account passcode
- 2 copies
- E2E encrypted cloud storage

Data Type	Tier	Storage Location	Control Details
Private keys	SECRET	[1. Security key 2. Encrypted USB 3. Safety deposit box paper backup]	[All copies > 256-bit encryption All copies air-gapped Encryption passwords stored in password vault]
Cryptocurrency seed phrases	SECRET		
[Add your own]	SECRET		

Financial records (tax, banking)	CONFIDENTIAL	[Encrypted vault / local drive]	FDE + offline backup + no cloud sync
Legal documents (wills, contracts)	CONFIDENTIAL	[Fireproof safe + scanned copy]	Physical original + encrypted digital copy
Identity documents (passport, SSN)	CONFIDENTIAL	[Physical safe / vault]	Never stored unencrypted digitally
Password vault	CONFIDENTIAL	[Password manager]	MFA on vault + offline emergency export
Irreplaceable personal files	CONFIDENTIAL	[NAS + cloud backup]	3-2-1 rule: 3 copies, 2 media, 1 offsite
Personal photos and videos	CONFIDENTIAL	[Cloud photo library + NAS]	Encrypted at rest + 2 copies
Email archive	CONFIDENTIAL	[Provider + local export]	Account MFA + periodic local export
Health and medical records	CONFIDENTIAL	[Patient portal + encrypted folder]	Encrypted storage, access restricted
Personal correspondence	CONFIDENTIAL	[Local device / encrypted folder]	Device FDE sufficient
[Add your own]	CONFIDENTIAL		
Installed applications	PUBLIC	Local device	None — reinstall from source
Cached and temporary data	PUBLIC	Local device	None
Downloaded media	PUBLIC	Local device / NAS	Single backup, best-effort
OS configuration	PUBLIC	[Dotfiles repo / config export]	Version-controlled config repo
[Add your own]	PUBLIC		

3. PERSONAL THREAT MODEL

Document only threats that realistically apply and the primary mitigation against them.

Threat	Likelihood	Impact	Primary Mitigation
Credential stuffing	HIGH	MEDIUM	Unique passwords + HIBP monitoring
Phishing	HIGH	HIGH	Hardware key MFA on high-value accounts
Device theft / loss	MEDIUM	MEDIUM	FDE + remote wipe configured
Opportunistic malware	MEDIUM	HIGH	AV, DNS filtering, limited installs
Ransomware	LOW	HIGH	Air-gapped offline backup
Financial fraud	MEDIUM	MEDIUM	Transaction alerts + credit freeze
[Custom threat]			

4. ACCEPTED RISKS

Every deliberate security tradeoff must be documented here. An undocumented risk is an oversight, not an acceptance.

Risk 1 — [SMS MFA on bank account — TOTP not supported]

Review by: [YYYY-MM-DD]

Justification: [Bank does not offer hardware key or TOTP. Mitigated by transaction alerts and monthly account review.]

Risk 2 — [Device X is end-of-life — replacement planned]

Review by: [YYYY-MM-DD]

Justification: [Budget constraint. Device not used for sensitive tasks. Replacement scheduled for [Month Year].]

Risk 3 — [Add accepted risk]

Review by: [YYYY-MM-DD]

Justification: [Justification and mitigating controls.]

5. SECURITY TOOLING REGISTER

Recovery keys and credentials should be secured elsewhere — record reference locations only here.

Category	Tool	Notes / Recovery Location	Last Audited
Password manager	[Bitwarden / 1Password]	Emergency sheet at: [location]	[YYYY-MM-DD]
MFA authenticator	[Aegis / Raivo]	Encrypted backup at: [location]	[YYYY-MM-DD]
Hardware key	[YubiKey 5 — 2×]	Backup key stored at: [location]	[YYYY-MM-DD]
Local backup	[Time Machine / rsync]	External drive at: [location]	[YYYY-MM-DD]
Cloud backup	[Backblaze / Restic+B2]	Encryption key: in vault	[YYYY-MM-DD]
DNS filtering	[NextDNS / Pi-hole]	Config ID: [ID] — in vault	[YYYY-MM-DD]
VPN	[Mullvad / ProtonVPN]	Account credentials: in vault	[YYYY-MM-DD]
Breach monitoring	HIBP	All email addresses enrolled	[YYYY-MM-DD]
Outbound firewall	[Little Snitch / Lulu]	Rule backup at: [location]	[YYYY-MM-DD]
Credit monitoring	[Service name]	All three bureaus enrolled	[YYYY-MM-DD]
[Add]			[YYYY-MM-DD]

6. REVIEW & AUDIT LOG

Record every review and any findings, remediations, or changes.

Date	Type	Findings	Actions Taken
[YYYY-MM-DD]	Annual	Initial policy created	All sections completed
	Ad-hoc		
	Annual		

7. BACKUP RESTORE TEST LOG

Test backup restore at least quarterly. Document the date, backup source, scope, result, and any relevant notes.

Date	Source	File / Scope Restored	Pass/ Fail	Notes	Integrity Check
	Local backup		✓		✓
	Cloud backup		—		—
	Local backup				
	Cloud backup				
	Local backup				
	Cloud backup				
[YYYY-MM-DD]	Full rehearsal	Complete system restore	✓	Annual — bare metal	✓

8. INCIDENT LOG

Every security event, however minor. Record what happened, how it was handled, and what changed as a result.

Date	Type	What Happened	Response	Changes Made
[YYYY-MM-DD]				

9. EMERGENCY REFERENCE

Print this section and store with physical secure documents. Reference locations only — no credentials here.

Password Manager

Manager: Bitwarden / 1Password / KeePass

Master password at: Physical location — not the password

Emergency contact: Name and how to reach them

Backup codes at: Physical location

Financial Emergency

Primary bank fraud line: Number on card

Credit card fraud line: Number on card

Credit freeze PINs at: Location — not the PINs

Device Remote Lock / Wipe

Apple Find My: icloud.com/find

Google Find My Device: android.com/find

Primary Email RecoveryProvider: Gmail / iCloud / otherRecovery phone: Last 4 digits onlyBackup email: AddressBackup codes at: Physical locationMicrosoft Find My Device: account.microsoft.com/
devices**Credit Bureau Freeze**

- ☐ Equifax — 1-800-349-9960
- ☐ Experian — 1-888-397-3742
- ☐ TransUnion — 1-888-909-8872

Store the digital version encrypted in your password manager. Print Section 9 and keep it in a fireproof safe or with your legal documents. Rewrite Sections 1–4 at every annual review.